Security Scan Report: BANDIT

Report ID: 61c3de31-4a88-4d83-8dc2-bf0aba0b36c3 | Generated: 2026-10-26 13:14:21 UTC | Operator: analyst@vadl.local

1. Assessment Scope & Target Identification

Target Scope / Component:	VADL Local Laboratory Target
Target URI / Source Path:	`http://127.0.0.1:5000`
Target Edition:	N/A
Authorized Lab Scope:	Yes (Verified Local Lab Target)
Security Scanner Tool:	bandit (vN/A)
Operational Scan Profile:	baseline
Scan Execution Status:	COMPLETED
Execution Duration:	N/A

2. Assessment Methodology

This automated security evaluation was conducted using BANDIT operating under the baseline profile within the isolated laboratory environment. Testing activities were strictly bounded to approved local components and verified against the authorized target registry prior to execution. Findings were normalized into canonical schema and deduplicated using stable SHA-256 fingerprinting.

3. Findings Summary & Severity Distribution

Severity Level	Count	Classification Criteria
CRITICAL	0	Direct remote code execution or widespread authentication compromise.
HIGH	0	SQL injection, IDOR with data leakage, or stored privilege escalation.
MEDIUM	0	Reflected cross-site scripting or missing CSRF protections.
LOW	0	Security header omissions or verbose server error banners.
INFORMATIONAL	0	Architectural observations and non-exploitable configuration notes.

TOTAL FINDINGS	2	Consolidated normalized findings count across all categories.

4. Detailed Technical Findings

Finding #1: SQL Injection String Formatting Vulnerability   [HIGH]

Vulnerability ID:	B608	Confidence:	HIGH
CWE Identifier:	CWE-89	OWASP Category:	A03:2021-Injection
Affected Component:	`app/lab/vulnerable_blueprint.py`	Lifecycle Status:	RESOLVED

Description: Possible SQL injection vector via dynamic string interpolation in search handler.

Remediation Guidance: Use SQLAlchemy parameter binding or db.session.execute(statement, params).

Sanitized Technical Evidence:

```
SELECT * FROM lab_products WHERE category = '' OR '1'='1'
```

Finding #2: Cross-Site Scripting Unescaped Template Rendering   [MEDIUM]

Vulnerability ID:	B703	Confidence:	HIGH
CWE Identifier:	CWE-79	OWASP Category:	A03:2021-Injection
Affected Component:	`app/templates/lab/vulnerable_guestbook.html`	Lifecycle Status:	NEW

Description: User-supplied guestbook message displayed without HTML contextual escaping.

Remediation Guidance: Enforce Jinja autoescaping or use html.escape() before presentation.

Sanitized Technical Evidence:

```
<p>{{ message|safe }}</p>
```

5. Remediation Recommendations & Verification Workflow

To successfully remediate findings discovered during testing, engineers must apply input parameterization (SQL injection), output contextual encoding (XSS), server-side ownership authorization checks (IDOR), and defensive HTTP security headers. Defenses must not be considered verified through manual assertions alone; they must undergo automated regression verification via the VADL Phase 5 remediation engine.

6. Limitations & Interpretation of Results

IMPORTANT SECURITY NOTICE: The absence of automated findings does not prove an application is completely secure. Automated tools and scenario adapters evaluate designated rule subsets and local execution paths only. Business-logic flaws, complex race conditions, and zero-day attack vectors may remain undetected. Results must be interpreted in conjunction with thorough architecture review and manual penetration testing.

7. Conclusion & Recommended Next Steps

The evaluation for scan #1 concluded with status COMPLETED. A total of 2 normalized findings were recorded. Recommended next steps: (1) Review confirmed critical and high severity findings; (2) Link findings to remediation tickets; (3) Deploy hardened code to the secure target edition; and (4) Re-execute automated verification regression suites.